

1/10



File No.: EXP202212829

RESOLUTION FOR FILING OF PROCEEDINGS

From the proceedings carried out by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: Various complaints have been filed with the Spanish Agency for Data Protection (hereinafter, the complainants) against UNICAJA BANCO, S.A.U. with NIF A93139053 (hereinafter, the complained party). The dates of submission of the various complaints are as follows:

21/10/2022: A.A.A.

03/11/2022: B.B.B.

03/01/2023: C.C.C.

21/01/2023: D.D.D.

23/01/2023: E.E.E.

03/02/2023: F.F.F.

03/02/2023: G.G.G.

01/03/2023: H.H.H.

21/06/2023: I.I.I.

The aforementioned complainants, all of whom are clients of the complained party, state that they have been victims of fraud by cybercriminals posing as employees of the entity. This fraud consisted of the complainants obtaining, by combining smishing, vishing, and social engineering techniques, the security codes that validated the money transfer operations from their accounts to those of the fraudsters. The complainants believe that the complained party has not been diligent in warning its clients about these potential frauds, especially in the context of the merger with another entity, as they claim that during the process of this merger, a security breach may have occurred that allowed cybercriminals access to their personal data.

Among the documentation provided by the various complaints, the following stand out:

- Expert report submitted by a complainant linking the occurrence of the events described in the complaints to the acquisition of personal data via the internet, which has been auctioned and subsequently used.
- Recording of the fraudulent call to one of the complainants.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/10

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the various complaints were forwarded to the complained party for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The notifications, which were carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), were received and responded to by the complained party in the terms outlined in the investigative proceedings that are subsequently presented.

THIRD: In accordance with Article 65 of the LOPDGDD, the submitted complaints were admitted for processing.

FOURTH: The General Sub-Directorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the details presented below.

Of the ten complaints admitted for processing, it is evident that in nine of them, it was the complainants themselves who provided the banking data to the cybercriminal posing as working for the complained party. This data was what allowed the fraudulent operations that caused them economic harm. In the tenth complaint, the complainant only states having received a fraudulent phone call and an SMS impersonating the complained party, without having provided any data or suffering any economic harm.

Relationship between the fraudulent actions and the data breach of May 20, 2022, reported to this authority. The aim is to determine, first, whether the facts described in the complaints are related to the aforementioned breach suffered by the complained party, which was duly reported by it on June 3 of that same year. To this end, additional information regarding the reported breach was requested from the entity, to which a written response was received, highlighting the following aspects:

- In May 2022, the production deployment of ***TOOL.1 was carried out as the tool for sending communications to clients in that entity. This tool was already used by the merged entity prior to the technological integration with the complained party and provided by the supplier ***SUPPLIER.1 through a license and maintenance contract. This tool aims to aggregate information about financial statuses to subsequently be printed and sent by regular mail to clients.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/10

- After its implementation in the productive environment, the first processes for generating and sending communications through the tool began to be executed, with no anomalies detected in the data during the first days, although there were delays in the execution times of the tasks.

- When the provider modified the application programming in order to reduce this delay, a race condition was generated, causing errors in the postal addresses of some clients who received letters with the data of another client.

- After confirming the occurrence of the incident with the provider, the different stakeholders (including the DPD and Cybersecurity of the responding party) were involved, and the measures to be taken for its rectification were agreed upon.

- On June 3, 2022, the breach was communicated to the present authority, complying with the requirements of the regulations. Additionally, after the communication of the incident, the following actions were carried out:

- o A report was requested from the tool provider regarding the incident, its causes, and possible corrective measures to be adopted.

- o The generation and printing of new documents were blocked.

- o A rollback process was carried out on the configuration that had caused the incident, verifying that it was not replicated in new executions.

- o Correos was notified to halt pending shipments.

- o Pending communications that had not yet been launched were deleted.

- o The provider carried out the necessary tasks to resolve any alterations in the clients' data that could be associated with the incident.

- The impact of the incident was limited to paper shipments, with no impact on clients who receive communications electronically.

From all the above, it is not possible to determine that the reported security breach, resulting from human error in the configuration of a tool, caused the events described in the claims subject to this file. Relation to the absorption of Liberbank S.A. by the responding party. On July 26, 2021, the merger by absorption of Liberbank S.A. by the responding party took place. As a result of the merger, Liberbank S.A. was extinguished, and its assets were transferred en bloc to the responding party, which has therefore succeeded, by universal succession, in all its rights and obligations.

The responding party provides the report issued by the Cybersecurity and Technological Risk Area regarding the measures adopted to ensure the security, integrity, and confidentiality of personal data in the process of migrating computer systems carried out after the integration of Liberbank S.A.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

4/10

The report outlines the measures taken to warn clients of possible fraud attempts during the system migration process following the absorption, including, among other matters, the following:

Carefully review the messages you receive by email or SMS. Cybercriminals may take advantage of the technological integration process to commit their frauds. #Don'tBite.

If you have any doubts, contact us via Messenger or call us at 952 076 263.

Be careful!

Do not open files or click on links from unknown and/or suspicious senders. If in doubt, contact us via social media.

Do not click on links in SMS messages that urge you to provide personal or financial information.

From the aforementioned report, it is concluded that no failures have been detected in the computer migration and/or the existing security protocols in the responding party that have been related to the alleged frauds claimed against the entity. All this is without prejudice to the fact that, taking advantage of the integration, criminals may have intensified their attacks on this group.

Informational and awareness campaigns Regarding phishing, vishing, or smishing fraud techniques, the responding party indicates that it has been conducting multiple informational and awareness campaigns on social networks, in the media, on its own website, at ATMs, and in remote banking services to prevent such frauds, including clear messages of preventive actions to its clientele. To substantiate this point, the following documents are provided:

- Report from the Social Media Department. This report includes all the informational-preventive cybersecurity publications disseminated through the responding party's social media from its inception in June 2018 to June 2023.
- Report from the Social Media Department listing the articles published in Uniblog. This report includes all articles on Cybersecurity published in UniBlog from its inception in October 2018 to June 2023. Uniblog is the corporate blog of the responding party and has a specific category for cybersecurity where all articles with service information are grouped, addressing in depth issues of interest to help users understand how cyber fraud works and how to prevent it. Currently, there are a total of 38 articles in the cybersecurity section, which, in addition to being permanently published on the blog itself, are disseminated through social media profiles to amplify their reach to the widest possible audience.
- Content of posters displayed in the network of offices of the responding party with advice on how to avoid digital fraud.
- Content of emails sent to clients with active digital banking in the last three months, or who made purchases in e-commerce in

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

5/10

the last six months. Four emails were sent with advice on preventing phishing, vishing, and smishing, as well as on creating a secure password.

- Announcements aimed at preventing digital fraud published across the entire network of ATMs of the responding party.
- Report from the Cybersecurity and Technological Risk Area detailing the measures, both specific and permanent, adopted regarding informational and awareness campaigns, both external and internal with external impact, carried out by the Entity for the prevention of phishing, vishing, or smishing fraud during the year 2022, in which the technological integration of the platforms of the responding party and Liberbank S.A. took place.

- Additionally, it includes the actions carried out regarding the origin of Liberbank S.A. in the weeks prior to the technological integration.

Monitoring services and threat closure on the internet (...)

Evaluation of the effectiveness of the measures. Furthermore, regarding the notable increase in the number of claims filed by clients who have been affected by third-party fraud using phishing, smishing, vishing, and spoofing techniques, the responding party is requested to clarify whether it has found any justification in this regard, whether it has evaluated the effectiveness of the measures implemented, and whether it has carried out any additional actions.

In this regard, concerning the justification for the increase in the number of claims, it conveys that it understands this to be a global increase in the use of these techniques to carry out fraudulent actions, which have affected not only clients of banking entities but also users of other services such as email or parcel services, even users of public services, with public entities such as the Tax Agency or the Social Security Treasury being impersonated.

It points out that this has motivated repeated awareness campaigns by associations, public bodies, the banking entities themselves, and, in particular, the responding party, which has documented them within the framework of the current investigation proceedings.

It cites, due to its relevance concerning banking entities, the Complaints Report of 2022 published in October 2023 by the Bank of Spain, which confirms this increase within the banking sector.

It highlights that this data confirms the forecast of an increase in cybercrime noted by the Secretary of State for Security of the Ministry of the Interior in its Report on Cybercrime in Spain 2022.

Customer Data Auction and Sale Campaign In the context of the investigation proceedings, the responding party is asked whether it is aware of the existence, in August 2022, of a campaign for the auction and sale of customer data from its Entity through Telegram channels, where phishing procedures and password theft would also be sold.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/10

The responding party claims to have no knowledge of the auction and sale of customer data through Telegram channels; however, it has been aware of the sale of customer data through various markets, from information obtained from the infection of customers' devices with different types of malware.

It has not been possible to verify the content of the announcement of the alleged sale on the mentioned Telegram channel, nor that such content consists precisely of personal data belonging to customers of the responding party.

Judgments and Extrajudicial Agreements In the data reported by THE RESPONDING PARTY for the requested period, from January 2021 to February 2023, it includes, concerning the refund of the claimed amounts, the number of judgments issued, the number of judicial proceedings in which the corresponding judgment is pending, and the number of extrajudicial agreements reached.

(...)

LEGAL GROUNDS

I

Competence

In accordance with the functions conferred on each supervisory authority by Article 57.1 a), f), and h) of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR) and as provided in Articles 47 and 48.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to resolve these investigation proceedings.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, to the extent that they do not contradict them, by the general rules on administrative procedures."

II

Security and confidentiality of processing

Article 32 of the GDPR stipulates the following:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/10

- a) pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process of regular verification, evaluation, and assessment of the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The data controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law.

It is necessary to point out that the aforementioned provision does not establish a list of specific security measures according to the data being processed, but rather establishes the obligation for the controller and the processor to apply technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity for the rights and freedoms of data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of technical and organizational measures must be made taking into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, and the process of verification (which is not an audit), evaluation, and assessment of the effectiveness of the measures.

In any case, when assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial damage.

In this regard, Recital 83 of the GDPR states that "(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, C/ Jorge Juan, 6 www.aepd.es 28001 – Madrid sedeagpd.gob.es

8/10

The responsible party or the person in charge must assess the inherent risks associated with the processing and apply measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be considered, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which are particularly likely to cause physical, material, or immaterial harm. In relation to the integrity and confidentiality of the data, point f) of Article 5.1 of the GDPR advocates: "1. Personal data shall be:

(...)

f) processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures ('integrity and confidentiality')."

III

Conclusion

Taking into account the principle of the presumption of non-existence of administrative liability until proven otherwise as provided in Article 53 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the investigative actions carried out lead to the conclusions that are presented below.

During the course of the investigation, it has not been possible to establish the existence of a direct causal relationship between the fraudulent activity of cybercriminals and the personal data breach that occurred previously. The available information shows that the data breach in May 2022 occurred as a result of human error arising from the integration of the banking entities. This breach was not a massive leak of data in electronic format, but rather occurred as a result of the sending of postal shipments to other clients different from the intended recipients, a breach that was also duly communicated to the present authority. The fraudulent activity, on the other hand, appears to have occurred through the mass and indiscriminate sending of messages to various users by the cybercriminals taking advantage of the merger between the aforementioned entities.

It is also appropriate to highlight that the entity being claimed has provided documentation regarding the measures implemented to prevent fraudulent activities and protect data security, including various informational and awareness campaigns regarding this type of cybercrime.

In the same way, as can be inferred from the investigative actions, no failures have been detected in the IT migration and/or security protocols.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/10

that it is not possible to determine that such migration has a direct relationship with the facts subject to the claims. This absence of a causal relationship does not prevent, as indicated in the previous proceedings, that cybercriminals may have intensified their attacks by taking advantage of the integration of the entities.

Finally, regarding the possible sale of data through social networks, no solid evidence has been obtained to support the existence of sales or improper disclosures of personal data of the claimed entity on a Telegram channel or other means. Specifically, it has not been possible to verify that the content of the mentioned advertisement on the social network contains personal data of clients of the claimed entity.

As can be seen, the lack of conclusive evidence prevents the attribution of responsibility to the entity regarding the reported fraudulent activities. Therefore, based on what has been indicated in the previous paragraphs, no evidence has been found that substantiates the existence of an infringement

within the jurisdiction of the Spanish Agency for Data Protection, all without prejudice to any possible subsequent actions that this Agency may carry out, applying the investigative and corrective powers it holds.

Thus, since it has not been possible to attribute responsibility to the claimed entity regarding the fraudulent activities against the claimants, in accordance with what has been indicated by the Director of the Spanish Agency for Data Protection,

IT IS AGREED:

FIRST: TO PROCEED TO FILE the present proceedings.

SECOND: TO NOTIFY this resolution to UNICAJA BANCO, S.A.U. and to the claiming party.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative process as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, and in accordance with the provisions of Articles 112 and 123 of the aforementioned Law 39/2015, of October 1, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

940-301023

Mar España Martí

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/10

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es